

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：II2 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 1 頁，共 15 頁

單選題 50 題 (佔 100%)

B	1. 網路防火牆的訪問控制列表 (Access Control List, ACL) 指的是下列何項？ (A) 列出所有使用者帳號 (B) 定義哪些流量可以通過防火牆 (C) 記錄網路活動 (D) 阻止惡意軟體
D	2. 有關 BadUSB 的敘述，下列何者正確？ (A) BadUSB 是一種惡意軟體，僅會感染 USB 隨身碟內的檔案資料 (B) BadUSB 攻擊僅限於 Windows 作業系統，不會影響 macOS 或 Linux (C) BadUSB 攻擊無法被一般的防毒軟體偵測並阻擋 (D) BadUSB 利用修改 USB 裝置的韌體，使其在電腦上被辨識為其他硬體裝置 (如鍵盤)
B	3. 下列哪一種攻擊手法主要是透過大量的請求來使目標系統無法正常運作？ (A) 魚叉式釣魚 (Spear phishing) 攻擊 (B) 阻斷式服務 (Denial of Service, DoS) 攻擊 (C) 中間人 (Man-in-the-Middle, MITM) 攻擊 (D) SQL 注入 (SQL Injection) 攻擊

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：II2 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 2 頁，共 15 頁

B	4. 在 SSL/TLS 通訊協定中，客戶端與伺服器會在握手階段（Handshake）交換金鑰與協定版本資訊。下列何項最能說明為什麼在握手過程中要同時交換「隨機數（Random Values）」與「Session ID」等資訊？ (A) 為了減少握手所需的封包傳輸次數，提升傳輸速率 (B) 為了確保金鑰獲取（Key Derivation）具有多樣性與不可預測性 (C) 為了讓伺服器能夠在握手過程中壓縮客戶端的傳輸內容 (D) 為了讓客戶端在握手後能夠複用過去的憑證（Certificate）而不再驗證
C	5. 當配置 DMZ（Demilitarized Zone）時，通常放置在該區域的伺服器是下列何項？ (A) 內部員工專用檔案伺服器 (B) 公司內部財務資料庫伺服器 (C) 需對外提供服務的 Web 或郵件伺服器 (D) 個人用電腦
C	6. 下列何者最能描述「ARP 詐騙（ARP Spoofing）」的攻擊手法？ (A) 改寫目標伺服器上的帳號密碼 (B) 竄改 DNS 伺服器的 IP 紀錄 (C) 竄改區域網路中 MAC 與 IP 對應 (D) 強行中斷 TCP 三向交握（Three-way Handshake）

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 3 頁，共 15 頁

D	7. 在資料完整性保護上，當使用雜湊函數（例如 SHA-256）進行訊息驗證時，下列哪種方法最能防止「長度延展攻擊（Length Extension Attack）」？ (A) 直接使用 SHA-256 雜湊結果作為簽章 (B) 使用常見的 MD5 雜湊函數來保護資料 (C) 在雜湊前對訊息加上高熵的隨機鹽值（Salt），並在驗證時同樣加入該鹽值 (D) 使用 HMAC（Hashed Message Authentication Code）機制進行驗證
C	8. 當突然發現區域網路中，有大量的電腦連線並傳輸不明的資料時，請問最有可能是下列何種網路攻擊？ (A) 分散式阻斷服務攻擊（Distributed Denial-of-service Attack，DDoS） (B) 中間人攻擊（Man-in-the-Middle Attack，MITM） (C) 蠕蟲（Worms） (D) 鍵盤側錄（Keylogging / Keystroke Logging）
C	9. 有關狀態檢視防火牆（Stateful Inspection Firewalls）以及封包過濾防火牆（Packet Filter Firewalls）之敘述，下列何者錯誤？ (A) 狀態檢視防火牆是基於 TCP/IP 協定特徵而發展出來的功能 (B) 狀態檢視防火牆使用「狀態表」來確認任何進入流量 (C) 封包過濾防火牆基於 OSI 模型的第 4 層-傳送層（Transport Layer）運作 (D) 封包過濾防火牆會針對 IP 封包的標頭加以檢查，藉以過濾掉非法封包

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 4 頁，共 15 頁

D	10. 在網路通訊中，數位憑證的主要作用是下列何項？ (A) 加速網路傳輸速度 (B) 過濾垃圾郵件 (C) 壓縮檔案大小 (D) 驗證通訊對象的身份
B	11. 在網路通訊中，中間人攻擊（Man-in-the-Middle Attack）的主要目的是下列何項？ (A) 癱瘓目標系統 (B) 竊取或竄改通訊內容 (C) 感染惡意程式 (D) 偽造 IP 位址
C	12. 關於通訊安全的敘述，下列何者錯誤？ (A) 當兩個系統進行通訊時，務必確保系統透過安全通道進行通訊，獲授權存取雙方使用共用資源 (B) 安全通訊端層（SSL）是對網際網路通訊提供隱私、驗證和整合性的安全性通訊協定 (C) SSL 是通道加密，資料也加密保護 (D) 傳輸層安全標準（TLS）是標準網際網路通訊協定，可以加密處理電子郵件，確保郵件在傳輸過程中安全不外洩
D	13. 下列何者是虛擬私人網路（Virtual Private Network，VPN）的主要功能？ (A) 過濾垃圾郵件 (B) 加速網路速度 (C) 防止病毒感染 (D) 隱藏 IP 位址，加密網路流量

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 5 頁，共 15 頁

B	14. 在作業系統安全防護中，為了降低勒索病毒（Ransomware）的影響，下列何種作法最為有效？ (A) 停用所有網路連線以阻止病毒傳播 (B) 定期備份重要資料，並存放於離線或雲端安全儲存空間 (C) 只安裝作業系統更新，不安裝應用程式更新 (D) 透過簡單密碼來保護系統，減少複雜性
B	15. 下列有關網路釣魚（Phishing）的敘述何者正確？ (A) 主要透過加密程式來加密受害者電腦中的檔案 (B) 通常利用社交工程手法，偽裝成可信賴的實體，誘使受害者提供敏感資訊 (C) 攻擊途徑只會發生在電子郵件中，無法在社交媒體或簡訊中發現 (D) 安裝並更新防毒軟體可完全阻止網路釣魚攻擊
D	16. 為強化 Windows 作業系統安全，使用者在維護作業系統運作穩定性並降低資安風險，採取下列何項是最有效的方式？ (A) 向原廠購買有效授權 (B) 購買硬體防火牆進行防護 (C) 維持網路連線速率與提昇連線品質 (D) 定期進行更新與修補漏洞
D	17. Linux 作業系統日常維運常見的資安防護方式中，下列何者最「不」適切？ (A) 安裝 ClamAV 防毒軟體 (B) 拒絕 root 使用者遠端登入系統 (C) 啟動 SELinux 強化安全機制 (D) 將 Linux 作業系統關機

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 6 頁，共 15 頁

B	18. 在管理非法軟體使用時，下列何項最能有效防止員工安裝未授權軟體？ (A) 允許員工自行安裝軟體，但定期進行系統掃描和審計以確保合規 (B) 採用應用程式白名單，僅允許經批准的軟體安裝並限制其他軟體執行 (C) 定期檢查已安裝軟體，並由 IT 部門手動移除未授權軟體 (D) 設置軟體下載和安裝警告系統，提醒員工遵守公司政策
D	19. OWASP Top 10:2021 是網頁安全領域中經常被拿來參考的弱點種類，請問下列關於 OWASP Top 10:2021 的描述何項錯誤？ (A) A01:2021 - Broken Access Control：這個種類通常發生在程式沒有做好權限控管，導致可以讀取到其他使用者的資料，甚至可以切換權限 (B) A03:2021 - Injection：這個種類的弱點風險等級通常偏高，因為無論是 SQL Injection、Command Injection、Code Injection 都有可能造成伺服器資料外洩或是被取得控制權，必須嚴加防範 (C) A06:2021 - Vulnerable and Outdated Components：這個種類指的是企業的開發人員或系統維運人員沒有定期檢查程式套件、開發框架、作業系統的版本，導致企業使用的版本存在已知的弱點 (D) A10:2021 - Server-Side Request Forgery (SSRF)：這個種類的弱點經常被用在網路探勘或存取內網資料，不過因為這個種類排在 OWASP Top 10 第十名，威脅性不高，也很難搭配其他弱點一起使用，通常企業不需要優先修補

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 7 頁，共 15 頁

B	20. 面對來自於供應鏈的資安威脅防護，下列敘述何者正確？ (A) 供應商系統可以開放在網路上，不需要限制來源 (B) 供應商所提供的軟硬體，要經過測試檢驗方可上線 (C) 外部採購的軟體可以直接安裝使用 (D) 軟體供應鏈固定即可不需要評估漏洞風險
B	21. 下列哪一項是幽靈攻擊 (Spectre) 利用現代處理器的特性來竊取敏感資訊？ (A) 記憶體交換 (Memory Swapping) (B) 分支預測 (Branch Prediction) 和推測執行 (Speculative Execution) (C) 虛擬記憶體 (Virtual Memory) (D) 多重執行緒處理 (Multithreading)
D	22. 下列何項較「不」屬於作業系統上常見的惡意程式？ (A) 電腦病毒與蠕蟲 (Viruses & Worms) (B) 特洛伊木馬程式 (Trojan) (C) 間諜軟體與廣告軟體 (Spyware & Adware) (D) 網路釣魚郵件 (Phishing) 的連結
D	23. XSS (Cross-Site-Scripting) 與 SQLi (SQL Injection) 兩種攻擊方式均與輸入程式碼有關。請問關於這兩種攻擊的差別，下列敘述何項最為適當？ (A) SQLi 是一種用於攻擊 SQL 資料庫的駭客手法，而 XSS 攻擊可以存在於許多不同類型的程式語言，如 Python (B) XSS 攻擊用於從資料庫竊取資料，而 SQLi 攻擊用於將使用者重定向到攻擊者可以從中竊取資料的網站 (C) XSS 是一種用於攻擊 SQL 資料庫的駭客手法，而 SQLi 攻擊可以存在於許多不同類型的應用程式中 (D) SQLi 攻擊用於從資料庫竊取資料，而 XSS 攻擊用於將使用者重定向到攻擊者可以從中竊取資料的網站

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 8 頁，共 15 頁

D	24. 下列何項觀點才是正確的程式安全開發的精神？ (A) 可以交由工具來把關，針對掃出來的問題進行修復即可 (B) 資料都有加密儲存，而且透過安全通道傳輸，所以不會有問題 (C) 時間目標才是王道，安全是額外附加，所以最後再考慮 (D) 遵循安全開發指引，於寫程式初期即考量安全設計的概念
C	25. 在安全開發的最佳實踐中，為了防止使用者輸入惡意內容導致安全漏洞，開發者應該採取下列哪一種措施？ (A) 將使用者的輸入直接以常數的方式撰寫在原始碼 (Hard-Coding) (B) 將使用者輸入的資料直接儲存在資料庫中 (C) 驗證 (Validation) 並淨化 (Sanitization) 所有使用者輸入 (D) 僅針對管理員帳號檢查輸入
C	26. Cigital 機構所提出之軟體安全開發生命週期架構 (Software Security Develop Life Cycle, SSDLC) 中，下列何項「不」在該生命週期階段中？ (A) 需求定義 (Requirement Definition) (B) 設計 (Design) (C) 報告 (Report) (D) 部署 (Deployment)
B	27. 下列何項「不」屬於程式開發過程中的安全檢測項目？ (A) 動態應用系統安全測試 DAST (Dynamic Application Security Testing) (B) 系統冒煙測試 (Smoke Testing) (C) 原始碼測試 (Source Code Testing) (D) 白箱測試 (White Box Testing)

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 9 頁，共 15 頁

C	28. 在開發安全的應用程式時，使用者密碼應該如何安全儲存最為適當？ (A) 儲存於設定檔，方便管理員查詢 (B) 使用 SHA-1 進行雜湊後存儲 (C) 使用鹽（Salt）與 SHA-2 雜湊演算法存儲 (D) 直接儲存不做處理
D	29. 為了躲避安全研究人員的分析與惡意軟體偵測機制，某些惡意程式會嘗試偵測自己是否執行於沙盒環境（Sandbox）內，並在偵測到時隱藏或延遲執行惡意行為。下列何種方法「不」是惡意程式常見的沙盒偵測技術？ (A) 檢查系統運行時間是否極短，以判斷是否為剛啟動的虛擬環境 (B) 嘗試存取特定的虛擬機或沙箱環境特徵，如硬體資訊 (C) 檢查是否有鍵盤或滑鼠輸入活動，以確認系統是否由真人操作 (D) 自動將自身程式碼重新加密以防止靜態分析
B	30. 下列何項「不」是常用的弱點分類或評分標準？ (A) CWE（Common Weakness Enumeration） (B) CSRS（Common Security Risk System） (C) CVE（Common Vulnerability and Exposure） (D) CVSS（Common Vulnerability Scoring System）
D	31. 下列何項「不」是常用來觀察駭客攻擊行為的模型（Models）？ (A) MITRE ATT&CK (B) MITRE D3FEND (C) MITRE ENGAGE (D) MITRE DEFEND

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 10 頁，共 15 頁

C	32. 為了有效防禦惡意程式的入侵，下列哪一種做法最能幫助快速發現並處理可能存在的弱點？ (A) 一年一度書面審查所有系統和軟體 (B) 依賴員工在發現問題時主動報告 (C) 定期執行弱點掃描並立即修復發現的漏洞 (D) 將所有檔案加密以防止惡意程式進行存取
A	33. 若一台設備已無法修補特定漏洞，下列哪一項防護措施最「不」能有效防止攻擊者利用該漏洞進行攻擊？ (A) 安裝最新的應用程式更新，降低可能被利用的攻擊面 (B) 使用虛擬補丁技術，在網路層面阻止針對漏洞的攻擊流量 (C) 對該設備進行嚴格的存取控制，限制只有特定來源能夠存取 (D) 啟用入侵偵測和防禦系統（IDS/IPS），監控並阻擋可疑流量
C	34. 關於密碼（Password）要求的描述，下列何項最「不」適切？ (A) 於不同之應用系統中，系統管理者不使用相同密碼（Password） (B) 即使是系統管理者帳號，密碼（Password）不與任何人共享使用 (C) 為了套裝軟體維護上的安全要求，由廠商預先提供之密碼（Password），不要隨意變更 (D) 當使用密碼（Password）作為系統登入鑑別資訊時，需套用高強度密碼

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 11 頁，共 15 頁

B	35. 資料安全在量子時代遭受極大挑戰，下列因應對策何者較為適切？ (A) CPC 中央處理加密 (B) PQC 後量子加密 (C) EEG 橢圓曲線圖 (D) AGV 自動圖形向量
C	36. 某公司每次完整備份的資料量約略少於 800GB，公司的顧問建議在備份媒介的選擇上，每一個單一的儲存媒介，需可以完整存放其一次的備份資料，請問下列哪種儲存媒介較為合適？ (A) BD-R (B) LTO-2 (C) LTO-4 (D) DAT320
C	37. 對於保護儲存設備中的資料不被第三方竊取或篡改，下列何者描述最為適切？ (A) 使用對稱加密演算法，並將加密金鑰儲存在同一個設備上 (B) 可以對資料進行 Base64 編碼以隱藏資料內容 (C) 對資料進行加密保護，並額外使用 HMAC 來驗證資料完整性 (D) 將資料壓縮後再儲存於儲存設備
C	38. 當企業需要永久刪除機密資料，使用下列何種方法處置最為安全？ (A) 在作業系統中刪除檔案並清空資源回收筒 (B) 對硬碟使用標準格式化 (C) 使用資料覆寫工具或物理銷毀 (D) 將硬碟存放於安全的地方以防止存取

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：II2 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 12 頁，共 15 頁

C	39. 依據「資通安全責任等級分級辦法」之資通系統防護基準規範，以下對於「事件日誌與可歸責性」的描述何者正確？ (A) 資通系統應使用格林威治標準時間（GMT）作為系統的時戳標準 (B) 只要有需要，都可以任意存取日誌紀錄 (C) 從日誌完整性防護必須分為事前預防、事中監視及事後驗證等三種面向，可驗證日誌內容是否曾經遭到異動 (D) 將日誌備份至原日誌系統不同之實體系統，以驗證資料機密性
D	40. 日誌管理要求應定期執行日誌備分的任務，關於日誌管理的敘述下列何項有誤？ (A) 定期備份日誌至與原系統外之其他實體系統，以避免因實體主機損毀而造成原始資料與備份資料一併丟失 (B) 常見的日誌備份方式有建置日誌伺服器、NAS 及雲端空間等 (C) 可以利用磁碟與磁帶等儲存媒體存放備份資料 (D) 為避免備份相關弊端產生，驗證人員於檢視機關日誌紀錄時，不可以訪談相關權責人員

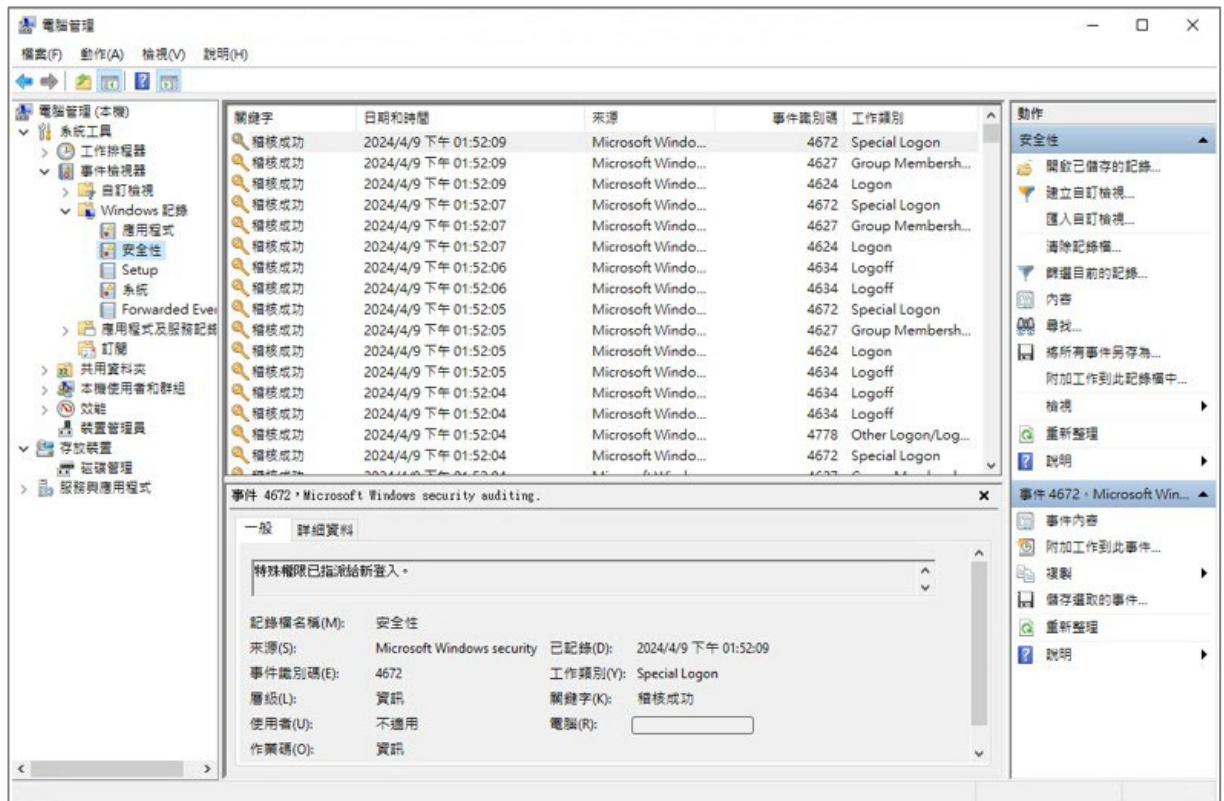
114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 13 頁，共 15 頁

- B 41. 請問如果你想要新建立一個常用的篩選結果，可以快速的進行查看，請問在附圖的介面中，該如何開始你的第一步？



- (A) 從右側動作中的「開啟已儲存的記錄」開始
- (B) 從右側動作中的「建立自訂檢視」開始
- (C) 從右側動作中的「儲存選取的事件…」開始
- (D) 從右側動作中的「將所有事件另存為…」開始

- D 42. 某網路管理員收到要求，需要開放在 DMZ 區的伺服器 A，讓其可以透過 RFC 5424 的協定寫入相關的日誌記錄到 DMZ 區以外的區域中的伺服器 B，請問以下列何項設定較為合適？

- (A) 允許所有伺服器到伺服器 B 的連線
- (B) 允許所有來自伺服器 A 到伺服器 B 的連線
- (C) 允許伺服器 A 至伺服器 B 中 TDP Port 514 的連線
- (D) 允許伺服器 A 至伺服器 B 中 UDP Port 514 的連線

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 14 頁，共 15 頁

B	43. 在數位鑑識調查中，為確保證據的完整性並能在法庭上被接受，下列哪一項原則較「不」適切？ (A) 在證據的扣押、蒐集、保管和運送過程中，應確保資料的一致性與完整性 (B) 為保持證據完整性，應利用加密機制保護數位證據 (C) 確保所有證據的取得、分析和儲存過程都被完整記錄並可被重現 (D) 其他人依據蒐證人員宣稱的鑑識程序應能得出相同的鑑識結果
B	44. 企業使用雲端服務時，下列哪一個資安技術較「不」屬於企業維運人員優先需要關注的？ (A) 身分識別與存取管理 (B) 實體安全 (C) 網站應用程式防火牆（WAF） (D) 資料隱私保護
B	45. 使用雲端資料庫與應用程式十分方便，但若設定稍有不慎將導致資料外洩或是服務遭到攻擊，下列何項是因設定不慎而導致問題，同時也列為 OWASP TOP 10 2021 之一的漏洞？ (A) Cryptographic Failures (B) Security Misconfiguration (C) Vulnerable and Outdated Components (D) Software and Data Integrity Failures
B	46. 智慧手機 APP 開發過程中，為了避免惡意程式的竊取或入侵，應該採用以下列何項方法？ (A) 使用明文儲存使用者的所有資料 (B) 定期更新和維護第三方程式庫 (C) 允許 APP 自動接受所有未經驗證的 SSL 憑證 (D) 為確保最佳的使用者體驗，故開放 APP 所有權限

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：II2 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 15 頁，共 15 頁

C	47. 在台灣，行動裝置的 App 要送「行動應用 App 基本資安檢測實驗室」檢測時，如果有金流及會員資料的，是屬於下列何項等級？ (A) L1 (B) L2 (C) L3 (D) L4
A	48. 在行動裝置安全機制中，下列何種技術可有效防止惡意應用程式竊取其他程式中的使用者資料？ (A) APP 沙盒（Application Sandbox） (B) DNS 解析（DNS Resolution） (C) 網路位址轉譯（Network Address Translation） (D) 藍牙配對（Bluetooth Pairing）
B	49. 在物聯網安全中，下列何種技術可有效防止設備與伺服器之間的通訊被竊聽或篡改 (A) Telnet (B) HTTPS (C) FTP (D) SNMPv1
D	50. 下列何項「不」是物聯網設備常見的問題？ (A) 預設密碼或使用弱密碼 (B) 缺乏安全的更新機制 (C) 缺乏設備管理 (D) 加密機制失效